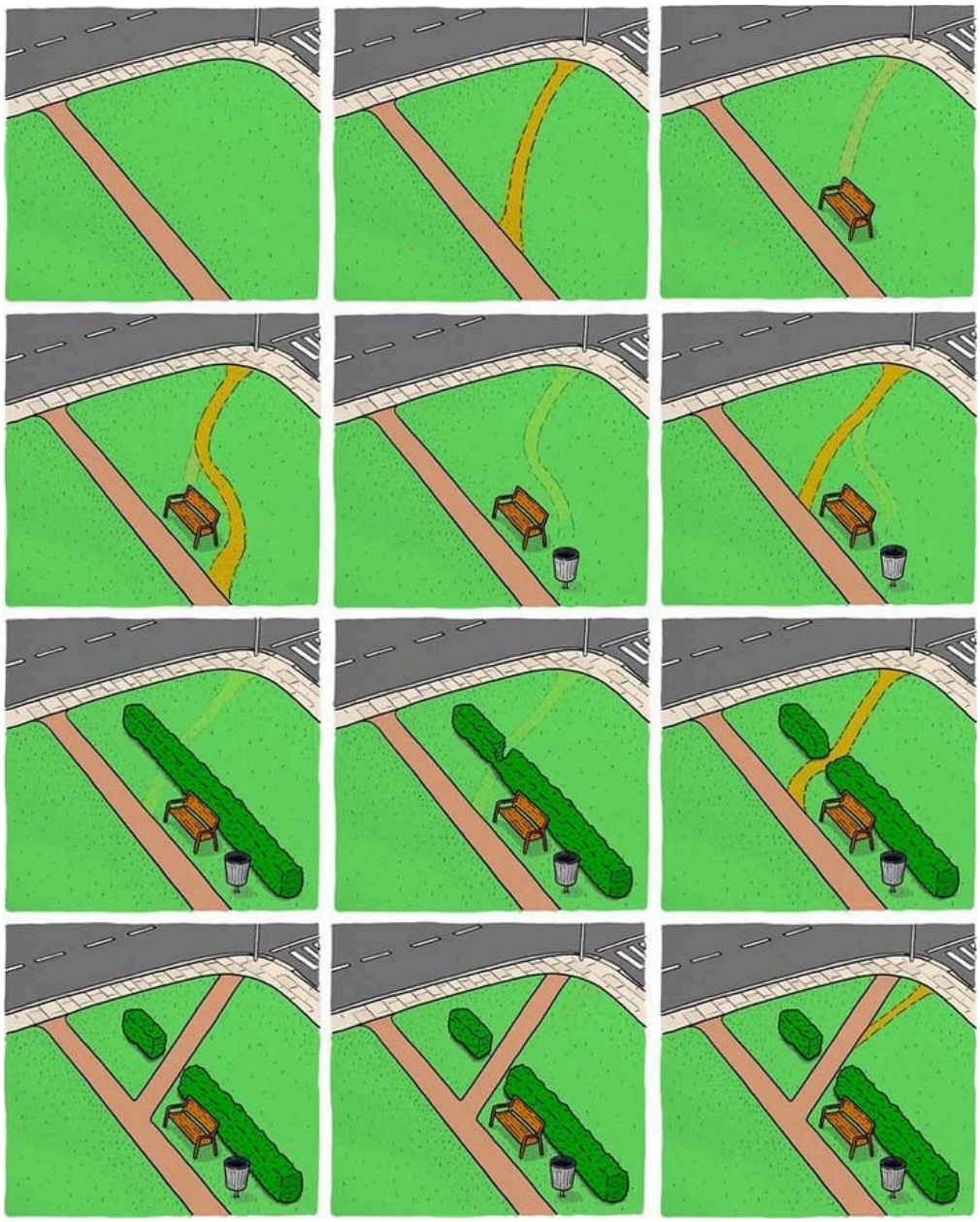
Security Now! #1054 - 12-02-25

Bots in the Belfry

This week on Security Now!

• Scattered Lapsus$ Hunters strikes (Salesforce) again. • Cisco actually (no kidding) sees the light. • Next week, Australia bans all underage social media. • The EU Parliament moves to replace US computer tech. • When to use Passwords, Passkeys or Yubikeys. • Do unpowered SSDs lose their data. • How about a "Joy of Coding" podcast. • A Bitwarden Passkeys integration glitch. • XSLT is sneaky. It's where you don't expect it. • We know where last week's picture came from. • The long-awaited return of a new Stargate series. • A simple test to check our networks for any bot infections.

People are gonna do (part II)...



Security News

Scattered Lapsus$ Hunters strikes (Salesforce) again

Salesforce's name has been dragged back into the news again due to another of their customers whose security is not up to snuff. Salesforce, who I'm sure is unhappy being dragged back into the news, posted a very limited and stiff acknowledgement, writing:

> *Security Advisory: Unusual Activity Related to Gainsight Applications*

Yeah. Unusual. As in, more than 200 customers had their Salesforce-stored data compromised. Salesforce continued with their terse posting:

> *Salesforce has identified unusual activity involving Gainsight-published applications connected to Salesforce, which are installed and managed directly by customers. Our investigation indicates this activity may have enabled unauthorized access to certain customers' Salesforce data through the app's connection.*
>
> *Upon detecting the activity, Salesforce revoked all active access and refresh tokens associated with Gainsight-published applications connected to Salesforce and temporarily removed those applications from the AppExchange while our investigation continues.*
>
> *There is no indication that this issue resulted from any vulnerability in the Salesforce platform. The activity appears to be related to the app's external connection to Salesforce. We have notified known affected customers directly and will continue to provide updates.*

All of the available evidence today supports everything Salesforce has said, but TechCrunch provides a much more fulsome account, thanks to their reporting of Google's Mandiant security group. TechCrunch's attention-getting headline was "Google says hackers stole data from 200 companies following Gainsight breach." They wrote:

> *Google has confirmed that hackers have stolen the Salesforce-stored data of more than 200 companies in a large-scale supply chain hack. On Thursday, Salesforce disclosed a breach of "certain customers' Salesforce data" — without naming affected companies — that was stolen via apps published by Gainsight, which provides a customer support platform to other companies. In a statement, Austin Larsen, the principal threat analyst of Google Threat Intelligence Group (TIG), said that the company "is aware of more than 200 potentially affected Salesforce instances."*
>
> *After Salesforce announced the breach, the notorious and somewhat-nebulous hacking group known as **Scattered Lapsus$ Hunters**, which includes the ShinyHunters gang, claimed responsibility for the hacks in a Telegram channel, which TechCrunch has seen. The hacking group claimed responsibility for hacks affecting Atlassian, CrowdStrike, Docusign, F5, GitLab, Linkedin, Malwarebytes, SonicWall, Thomson Reuters, and Verizon.*

Yikes! So not obscure entities no one has heard of before. TechCrunch said Google would not comment on specific victims, so TechCrunch did some more digging, writing:

> *CrowdStrike's spokesperson Kevin Benacci told TechCrunch in a statement that the company is "not affected by the Gainsight issue and all customer data remains secure." CrowdStrike*

confirmed to TechCrunch that it terminated a "suspicious insider" for allegedly passing information to hackers. TechCrunch reached out to all the companies mentioned by Scattered Lapsus$ Hunters.

Verizon spokesperson Kevin Israel said in a statement that "Verizon is aware of the unsubstantiated claim by the threat actor," without providing evidence for this claim.

Malwarebytes spokesperson Ashley Stewart told TechCrunch that the company's security team is "aware" of the Gainsight and Salesforce issues and "actively investigating the matter."

A spokesperson for Thomson Reuters said the company is "actively investigating."

Michael Adams, the chief information security officer at Docusign told TechCrunch in a statement that "following a comprehensive log analysis and internal investigation, we have no indication of Docusign data compromise at this time." However, Adams said that, "out of an abundance of caution, we have taken a number of measures including terminating all Gainsight integrations and containing related data flows."

At the time of publishing, none of the other companies responded to requests for comment.

Hackers with the ShinyHunters group told TechCrunch in an online chat that they gained access to Gainsight thanks to their previous hacking campaign that targeted customers of Salesloft, which provides an AI and chatbot-powered marketing platform called Drift. In that earlier case, the hackers stole Drift authentication tokens from those customers, allowing the hackers to break into their linked Salesforce instances and download their contents.

At the time, Gainsight confirmed it was among the victims of that hacking campaign. A spokesperson for the ShinyHunters group told TechCrunch "Gainsight was a customer of Salesloft Drift, they were affected and therefore compromised entirely by us." Salesforce spokesperson Nicole Aranda told TechCrunch that "as a matter of policy, Salesforce does not comment on specific customer issues." Gainsight did not respond to TechCrunch's requests for comment.

On Thursday, Salesforce said there is "no indication that this issue resulted from any vulnerability in the Salesforce platform," effectively distancing itself from its customers' data breaches.

Gainsight has been publishing updates about the incident on its incident page. On Friday, the company said that it is now working with Google's incident response unit Mandiant to help investigate the breach, that the incident in question "originated from the applications' external connection — not from any issue or vulnerability within the Salesforce platform," and that "a forensic analysis is continuing as part of a comprehensive and independent review." "Salesforce has revoked active access tokens for Gainsight-connected apps as a precautionary measure while their investigation into unusual activity continues," according to Gainsight's incident page, which said Salesforce is notifying affected customers whose data was stolen.

In its Telegram channel, Scattered Lapsus$ Hunters said it plans to launch a dedicated website to extort the victims of its latest campaign by next week. This is the group's modus operandi; in October, the hackers also published a similar extortion website after stealing victims' Salesforce data in the Salesloft incident.

TechCrunch finished their piece, writing:

The Scattered Lapsus$ Hunters is a collective of English-speaking hackers made up of several cybercriminal gangs, including ShinyHunters, Scattered Spider, and Lapsus$, whose members use social engineering tactics to trick company employees into granting the hackers access to their systems or databases. In the last few years, these groups have claimed several high-profile victims, such as MGM Resorts, Coinbase, DoorDash, and more.

I chose to share this story not only because it's certainly important to those companies who are doubtless scrambling around trying to determine what of their customer data may now be in the hands of extortion-happy criminals who are not shy about bragging to the press, nor about releasing stolen data when they are stiffed.

The bigger message here is the steadily growing consequences which arise from outsourcing. I'm not suggesting that the benefits do not outweigh the risks, only that risks which remain unseen and unappreciated cannot be hedged against nor planned for. When Cloudflare goes down, as we saw two weeks ago, it takes an appreciable portion of the web down with it. The same is true for AWS and Microsoft. From the perspective of the individual customers who have outsourced their needs to those providers, this is an inconvenience for several hours while their critical infrastructure is off the Internet. So collectively the total amount of pain is huge. But on the other hand, it's very likely that many of those individual providers are positioned behind Cloudflare to obtain the 24/7 benefits of Cloudflare's bot attack prevention and mitigation, and that were it not for Cloudflare on an individual basis, those companies would be periodically blasted off the Internet at the whim of random unknown attackers using today's inexpensive DDoS-as-a-service facilities.

So what does this have to do with Salesforce? The same principles are at play there. In the case of Salesforce, the new model is known as BPO – Business Process Outsourcing – where significant pieces of a business's operational requirements, where there would be a lot of wheel reinventing without much value to add, are instead outsourced to specialist providers.

While it makes sense from an operational standpoint to do that, we've just seen more than 200 of Salesforce's individual customers who were all using Gainsight's apps connected to Saleforce's backend API having the data of an unknown number of their customers exposed through no fault of their own. Recall that long ago there was that story of all of the dental offices that were compromised when the managed service provider they all used to outsource a bunch of their dental operations – probably dental insurance or dental billing – and their internal networks were all, in turn, hacked. This Gainsight/Saleforce event is an updated version of that and it's happening at a much greater scale because the services being offered have become much more granular and generic. The general idea is, let's not have anything in-house that we can sub-contract for. It makes companies far more dynamically resizeable, and it's far easier to terminate a contract for an outside service that's no longer needed than it is to terminate the employment of a department full of employees with whom multiple birthdays have been celebrated.

The unspoken of cost, however, is that our industry still has very significant operational security problems that show no sign of having been worked out. The fact that Salesforce's reaction to the breach is to invalidate a providers static access credentials, thus effectively excommunicating them and all of their users from having any access, strongly suggests to me that today's model of interacting networked applications is still far too crude to withstanding the sort of scaling that demand is creating.

I'm not close enough to the problems to propose any better solutions, but the way things are being done today feels wrong. I hope those who are in the trenches are thinking about how to make this all work in a more secure and robust fashion. The feeling is that these breaches are still being seen as exceptions that hopefully won't repeat. But they are repeating. All the evidence suggests that this is the wrong way to think about them. This feels like the Internet in the days before the concept of the firewall was introduced.

The general concept of widely distributed API-linked outsourced services seems to have proven itself. Now the industry needs to figure out how to reduce the blast radius when something evil manages to crawl into the network. What we know is that the more interlinked such complex systems become, the more fragile and vulnerable to malicious exploitation they are.

Christmas came early for Steve…

We all know that I frequently find fault – tremendous fault, actually – with the apparently cavalier attitude Cisco has always taken to security. We all know that change is difficult. And I get it that Cisco, being an early and pioneering commercial network equipment supplier was building routers way before security was even appreciated as an issue. As I've noted earlier, their original routers were running a large collection of often unneeded services by default and since those routers treat all of their network interfaces equally, without any concept of WAN or LAN, all of those services were bound to and available on all of the router's interfaces. And Cisco only slowly, and with apparent reluctance, change the behavior to not run those services by default.

We're back here today because of a short blurb that caught my eye. The blurb was titled *"Cisco's Resilient Infrastructure"* and it said: *"Cisco has announced Resilient Infrastructure, a project modeled after Microsoft's Secure Future Initiative program that aims to improve the security of its products."* <gasp! What?!> *"This includes "increasing default protections, removing legacy insecure features, and introducing advanced security capabilities which reduce the attack surface and enable better detection and response."* Oh, be still my heart! Never before have I been hoping that someone in a position of authority inside Cisco may have gotten wind of my thoughts about the problems with their approach to security. Now I hope they've been listening because although my wishes for what they might or could do are somewhat extreme, it would make so much difference for the future security of the Internet.

I went looking for what had triggered that short announcement. In their Executive Platform section I found the article titled: "Doubling down on resilient infrastructure". This was posted under the name of Anthony Grieco, a Cisco Senior Vice President & Chief Security & Trust Officer. The posting reads:

> *Global networks have faced relentless attacks for years with recent and dramatic increases in sophistication, scale, and speed. The current dynamic requires urgent change. Organizations must assess their current risk posture and use technology vendors' guidance and tools to securely implement, maintain, and operate their networks. We recognize that the vast amount of information across products and services from different vendors can create insurmountable complexity for customers attempting to secure their infrastructure. To that end, we are simplifying our offerings so that secure configurations, protocols, and features are the default. We are proactively alerting network administrators when insecure choices are being made and deprecating legacy methods that have served as operational mainstays for over two decades, all to create a more secure, resilient, and modern network.*

Did everyone just hear that? I could not have better expressed what they need to do. Anthony continues:

At Cisco, we have spent years making technology that allowed our customers the ultimate flexibility in how to configure and deploy networks. We also have a long history of constant improvement in the design of our portfolio to be secure and resilient to evolving threats, remaining trustworthy and transparent throughout its lifecycle, and equipping our customers with the tools and information they need to manage risk. This technology is useless if it is not deployed securely.

Running global networks is complex. While experts once thrived in this environment, today's landscape has turned past complexity into vulnerability. Network infrastructure that was designed, built, and deployed in decades past did not anticipate today's hostile security environment. This is further amplified by the fact that many organizations have not updated and maintained their network infrastructure, missing opportunities to fix known vulnerabilities and update configurations based on the latest security best practices.

A new Cisco-commissioned report found that 48% of network assets worldwide are now aging or obsolete, creating significant technical debt that diverts budgets toward maintenance rather than modernization. It is the equivalent of a city relying on a rusted, cracked bridge for all its traffic. As dependence on global networks grows, failing to break the current cycle of escalating threats could have a significant impact on our ability to trust future digital systems.

We believe it is the responsibility of all trustworthy vendors, including Cisco, to inform customers when the use of certain technology may expose them to potential risks. That is why we are doubling down on the model where security is the default and any reduction in security requires an explicit choice.

Wow. This sounds wonderful... and, as we've discussed, it is exactly the way to do it.

It moves our customers from facing unexpected risks to managing known and deliberate ones. In some cases, we will completely remove the ability to do things insecurely regardless of choice.

My god... is this really Cisco's senior VP, Chief Security & Trust Officer talking?

Today, we are announcing the next step in our security evolution focused on reducing the attack surface in our portfolio, increasing protection of sensitive data, and enabling the defender with more robust capabilities to monitor and detect threats in network infrastructure.

Resilient Infrastructure is a Cisco effort to strengthen network security by increasing default protections, removing legacy insecure features, and introducing advanced security capabilities which reduce the attack surface and enable better detection and response. Simply put, we are making it incredibly obvious when our customers are configuring insecure features that introduce new and unnecessary risks into their networks.

Oh, please be true.

Initially, customers will receive increased security warnings that recommend discontinuing the use of any insecure features. In subsequent releases, features will be disabled by default or require additional steps to allow for configuration. Eventually, insecure options will be removed entirely.

My god, it's like Christmas for security!

> *Most importantly, we are furthering our commitment to our customers, and the industry, to provide visibility in areas where customers and large network providers are exposed to risk. We encourage all technology vendors to adopt the same approach to transparency.*
>
> *Historically, network infrastructure has not received the same level of monitoring and scrutiny as other parts of the IT infrastructure…if it ain't broke, don't try to fix it. That is no longer the case. We want to emphasize the importance of, and make it even easier to perform, effective monitoring, detection, and response within network infrastructure when (not if) vulnerabilities and attacks manifest.*
>
> *Addressing newly discovered vulnerabilities often requires patching or updating systems, which can create operational disruptions and cause unwanted downtime. Instead of waiting for a patch or scheduling emergency upgrades, we will be designing features to deploy targeted real-time shields that protect against specific vulnerabilities soon after they are identified. This method allows teams to mitigate potential risks immediately, without the need to interrupt operations or perform unplanned maintenance. It means faster response to threats, fewer operational headaches, and a more resilient network, so critical services stay online, even as the threat landscape evolves.*

Okay. I'm just speechless now, except to say "Thank you, Cisco."

> *We know security and trust in technology will look different in 2040, as it did 15 years ago. As we evolve the network to be secure today, we must prepare for the future. It is crucial we get this right. The network is the foundational infrastructure that powers every aspect of our lives, enabling technologies like Artificial Intelligence (AI). We rely on the network to protect our most sensitive data, but quantum computing is poised to upend today's encryption algorithms, therefore, the network must evolve to support post-quantum cryptography (PQC) and must be secure by default. This is not simply a switch to be flipped in the next decade as AI becomes the norm and quantum computing inches towards mainstream adoption. Those that do not act now will unfortunately be doing so at their own peril.*
>
> *No measure can guarantee perfect security, but as the threat landscape evolves, so will our security practices. To put that promise into action, we will continue to invest in innovation to help our customers effectively manage risk, overcome threats, and work to earn and maintain their trust. We remain committed to raising the bar, giving defenders the tools they need to operate, detect and respond securely, and doing so with trust, transparency, and accountability.*
>
> *We urge all network operators to act now to comprehend and mitigate infrastructure risk. Actively protect your organization by keeping systems up to date, using secure configurations, and planning for device lifecycle management.*
>
> *Now is the time. As an industry we must raise the collective bar for securing our global critical infrastructure. Join us as we collectively move toward a more resilient future.*

Okay. Now I fully understand that it's one thing to say it and another thing to do it. But after reading this I'm not feeling at all cynical. This writing evidences an absolutely perfect grasp of the problem – which no one inside Cisco has ever before shown with their *"But didn't you read our optional device hardening guide?"* approach.

The HUGE sea change evident here is that Cisco is, for the first time ever, actually taking full and direct responsibility for the in-the-field operational security of their products. That's a switch from *"Read our optional device hardening guide"* to *"We no longer publish a device hardening guide because we built it all into our systems from the start."* I couldn't possibly ask for anything more from them and I hope that what they do, that the approach they take, will be seen and emulated by every other similar network equipment and services company.

It's 2025, almost 2026, and "Network Security" is no longer a buzz phrase that's given some lip service. Network security has become at least as important as performance – perhaps even moreso. So it's significant that anyone deploying any of this next-generation new Security First Cisco gear will, themselves, directly experience Cisco's demonstrated commitment to THEIR network security. That's got to be a sales-promoting feature. Feeling that Cisco has your back and is demonstrating that fact during device setup has got to be good for Cisco's sales and reputation. What I think this means is that what Cisco is doing is just good business. The world has evolved to the point where device security trumps features.

I'm so happy. The industry, the world, received an early Christmas present.

"Twitch assessed as age-restricted social media platform"

That's the headline of an announcement from the Australian government as legislators continue to lock down Internet content. Here's what Australia's eSafety Commissioner posted last week:

> *eSafety has informed Twitch it is considered an age-restricted social media platform required to take reasonable steps to prevent under-16s from having accounts, in accordance with Australia's Social Media Minimum Age legislation.*
>
> *Following Twitch's own self-assessment, eSafety assessed Twitch as meeting the criteria for 'age-restricted social media platform', because it has the sole or significant purpose of online social interaction with features designed to encourage user interaction, including through livestreaming content.*

Wow. So here it's not about the nature of the content at all, it's that Australian legislators do not want people under the age of 16 to be able to capture, post, share and interact about content. The announcement continues:

> *Twitch is a platform most commonly used for livestreaming or posting content that enables users, including Australian children, to interact with others in relation to the content posted.*

Oh, the horror!

> *eSafety has also informed Pinterest it does not consider it subject to age restrictions on the basis it does not currently meet the criteria for an 'age-restricted social media platform'. While Pinterest enables some online social interaction, it is not the significant purpose. Pinterest is more commonly used by individuals collating images for inspiration and idea curation.*
>
> *From December 10th, Twitch and the previously announced Facebook, Instagram, Kick, Reddit, Snapchat, Threads, TikTok, X and YouTube, will be required to take reasonable steps to prevent Australian children under the age of 16 from having accounts.*

Although it is ultimately a matter for the courts whether a service is an age restricted social media platform, eSafety undertook these assessments to assist Australian families and industry prepare for December 10th. eSafety expects all online platforms that operate in Australia to assess their obligations under Australian law, including the social media minimum age.

eSafety has provided a self-assessment tool to help industry understand if they are required to comply with the social media minimum age and remains in ongoing discussions with platforms about their compliance obligations and their planned approach towards compliance.

eSafety has been assessing platforms against the criteria set out in the social media minimum age legislation and the Minister for Communications' legislative rules over recent months. This work has occurred in stages, allowing eSafety to release information to the public as some preliminary assessments were completed, and while others were still underway.

There are no further assessments planned in the lead up to 10 December.

Wow. So much for Christmas in Australia.

Remember that the flip side of preventing anyone under the age of 16 from accessing Facebook, Instagram, Kick, Reddit, Snapchat, Threads, Twitch, TikTok, X or YouTube, is the **implicit** need to prove that anyone wishing to do so is at least 16 years old. Starting December 10th, Wednesday after next, every Australian must prove their age. And the world lacks any privacy-preserving way to do that.

https://www.esafety.gov.au/about-us/industry-regulation/social-media-age-restrictions/assessment

I went over to the eSafety self-assessment page to better understand what's going on. I have a link to that page in the show notes. Under the topic *"Definition of 'age-restricted social media platform'"* that page says:

An age-restricted social media platform is an electronic service which meets all these conditions:

- *It has the sole purpose, or a significant purpose, of enabling online social interaction between two or more end-users.*
- *It allows end-users to link to, or interact with, other end-users.*
- *It allows end-users to post material on the service.*
- *It has material which is accessible to, or delivered to, end-users in Australia.*
- *It is not an excluded service under the Rules.*

Excluded services are things like professional networking or professional development, support of education or health, facilitating communication between educational institutions and students (and/or their families) and facilitating communication between health providers and people using those services.

In other words, it is the intention of the Australian legislators to deliberately target what we all know of as modern online social media.

In that sense, what we have taking effect in Australia is tantamount to Mississippi's far over the top blanket prohibition on access to any and all social media within the state of Mississippi ... but this is being applied – starting the middle of next week – to the entire country of Australia.

All I can say is… what a mess.

EU Parliament urged to drop US computing solutions

Speaking of messes, Politico reported last week that more of Europe is wishing to move away from US-based computing solutions. The beginning of Politico's reporting wrote:

> *BRUSSELS — A cross-party group of lawmakers will urge the European Parliament to ditch internal use of Microsoft's ubiquitous software in favor of a European alternative, according to a letter obtained by POLITICO.*
>
> *The call comes amid fresh concerns that the dominance of a handful of U.S. tech giants has become too much of a liability for Europe's security and prosperity, and as the U.S. administration renewed demands for digital concessions at a meeting in Brussels on Monday.*
>
> *In the scathing letter to be delivered to Parliament President Roberta Metsola on Tuesday, 38 lawmakers also list the screens, keyboards and mouses from Dell, HP and LG — in use across the chamber's IT systems — as technology that should be ditched.*
>
> *The letter reads: "With its thousands of employees and vast resources, the European Parliament is best positioned to galvanise the push for tech sovereignty. When even old friends can turn into foes and their companies into a political tool, we cannot afford this level of dependence on foreign tech, let alone continue funneling billions of taxpayers' money abroad"*
>
> *The lawmakers cite a broad range of European alternatives they argue are viable solutions: from Norwegian internet browser Vivaldi, French search engine Qwant and Swiss secure email suite Proton to the German collaboration platform Nextcloud.*
>
> *The lawmakers wrote, praising the International Criminal Court's recent move to drop Microsoft over U.S. sanction fears: "Our mid-term goal should be the complete phase-out of Microsoft products, including the Windows operating system. It's easier than it sounds."*
>
> *"The Parliament's vehicle fleet is almost entirely made up of cars from European brands. The same can be replicated for end-product computer hardware." They call to set up a task group of lawmakers and Parliament staffers to help and monitor that transition.*
>
> *"With enough political will, we will have freed this institution from the danger of foreign tech dependency by the end of the mandate."*

I'm sure these very strong U.S. technology companies will survive, but interdependence creates stability because everything is about economics. So I'm sorry to see Europe pulling away from the U.S., though it's hardly surprising given the way relations have been during the past year. We, meaning the U.S., just need to be very sure that this is what we really want... because it's what we're getting.

Listener Feedback

Brian Garland

Steve, I've been using a password manager and long random passwords for some time now. I'm seeing options for passkeys and Yubikeys more frequently and realize I don't have a good feeling for the best practices for those options. Have you done a "best practices" segment for passwords/passkeys/hardware keys? If so, please point me in the right direction. If not, this might be a good segment for a future podcast. Thank you, Brian

That's a great question that we've never directly addressed. I think that the optimal answer has been changing while we (a) waited for our chosen password manager to add support for passkeys and (b) while we waited for the FIDO association to follow-up the passkeys functional specification with a passkeys import/export specification.

We don't yet have universal cross-platform passkeys transport in any common format. But we know that's coming. However, I would imagine that all of our listeners are using a single common password manager across all of their platforms, and both 1Password and Bitwarden completely support cross-platform passkeys synchronization. So this means that passkeys support is now entirely practical.

So what does this mean for Brian's question of best practices? It means that there is zero downside and only a significant upside to the use of a passkey and that option should be chosen whenever it's presented. Passkeys are clearly the future. Usernames and passwords are the past. So use a username and password when and until you have no other choice, but switch to authentication with a passkey whenever it's offered.

So what about Yubikeys?

As we've observed, security and authentication ***always*** requires the keeping of a secret of some kind. It's by proving that one knows the secret that one's identity is asserted since the assumption is that the holder of the secret will have successfully prevented its disclosure. The problem with the username and password system is that the only way of proving that one knows the secret is by providing it in some form to the relying party. This is the danger inherent with username and passwords – the secret is disclosed to prove knowledge of it.

That's what makes any public-key authentication system so much more secure. In a public key system like Passkeys, the relying party sends the authenticating party a unique piece of entropy to sign using their secret private key. When the signed entropy is returned to the relying party, that signature is verified using the authentication party's previously provided and stored public key. Since only the holder of its matching private key could have properly signed the entropy, the signer has proven their identity without disclosing their secret, which is their private key.

This means that the protection of a passkey's private key is paramount, which is where Yubikeys enter the picture. A Yubikey is an HSM – a hardware security module – which is capable of using previously stored private keys to sign a challenge in order to assert the identity of its holder. The Yubikey itself performs the signing operation so that the user's private key never leaves the key and can never be obtained or compromised.

But, that's both a blessing and its own annoyance, since the only way to authenticate anything that depends upon a Yubikey is with that Yubikey. That's what makes the Yubikey the most secure option available. But it also means that if you've left the Yubikey at home or at the office, it won't be available for authentication... and the fact that there's no work around for that is the

entire point of using it. And depending upon the model and generation of the Yubikey, it may have limited storage for passkey private keys. All of this argues for not using a Yubikey everywhere. You probably don't need it to login to Uber, Facebook or Instagram. But you might want to use it when accessing your online retirement investment accounts and anything you might be doing with your national government.

So I'd say that best practice would be to always use a passkey whenever possible in favor of old school username and password, and to use a hardware token-based passkey for the handful of sites that matter most and where having access to them tied to a physical device won't become a usage handicap.

Thomas Morrison

I had a discussion with a colleague today about whether an SSD would survive long in an environment where it was expected to write data once and only be read occasionally, if ever, such as a media server. The web is filled with warnings about not leaving SSDs unpowered for long periods or the charge levels can degrade, and claiming that due to periodic maintenance by the controller, an SSD that is powered on and idle won't have this problem. I find this hard to believe because any controller programmed to maintain cell charge would be re-writing cells that tested marginal, and that would also solve (or greatly reduce) the now infamous read disturb performance problems. Maybe some drives are doing this? I don't think I've heard you talk about this in the past, so what do you think?

A great deal of empirical evidence from SpinRite's users support the belief (which has become mine that's to the evidence) that keeping SSDs powered on does nothing to prevent the gradual deterioration of their data over time. It takes years. But people who use their laptops daily still experience a slowing down over time due to softening bits, accumulating errors, and the need for the SSDs controller to perform time-consuming error correction.

And I recall very clearly having Allyn Malventano tell me, in no uncertain terms, that an SSD will never perform autonomous writes to its media. For those who don't recognize his name, Allyn is about as high up in the pecking order of solid state storage gurus as it's possible to go.

The empirical experience from SpinRite's users who have run SpinRite over their SSDs at Level 3 to perform a single pass re-write of the drive's entire surface is that older drives had, indeed, slowed down over time and were completely rejuvenated by that rewrite. The only way to explain that is that those drives were not doing that on their own. I've heard the rumors of self-repairing SSDs – perhaps they persist because they make sense. But Allyn says those rumors are not true and tracks with SpinRite's before and after drive benchmark findings.

Gorbash 1370

Hi Steve, In Ep 1052 the Picture of the Week discussion pleasantly detoured into refactoring, and Leo floated the idea of a coding session/discussion. I just wanted to say how much I would love that!!

I'm a middle-aged coding novice (now about 3yrs of compulsive hobbying) who originally hoped to pivot into cybersecurity - there's a real irony in how AI coding assistants enabled me to learn /build so much faster while probably wiping out most of the entry-level opportunities that might once have made a related career switch possible!!🙄 I addictively persist with building because I love the process of coding, the utility, and the self-sufficiency it affords me.

Unfortunately, no one I know has much tech knowledge, let alone interest in code, so in human terms I'm learning largely on my own. Obviously I don't trust AI's sycophantic reflections on what is 'normal' when I have a vent about how long coding tasks are taking me. I'm embarrassed that a coding project that I thought would take me 'a couple of months' has silo-ed me into a code cave for nearly 2 years. I have zero real-world context for what's "normal" in terms of how coding feels or how long things take.

Over the years, some of your off-hand comments about coding have been unexpectedly important to me. You've mentioned sometimes returning to old code to have nearly forgotten how it works; about the steep cost of context switching in your reflections on the DNS-benchmark revamp... I thought I was just a crap coder for finding a few days away from a project to be such a wrench, and to take so long to decipher things I've written before. I can't overemphasise what a huge relief hearing these things was - I'd nearly convinced myself there was something wrong with me for having the same experience. You and Leo have commented how some coders simply aren't suited to being employees i.e. can only really dev as their own bosses - hearing that framed without judgement was another relief.

All of that is why I'd be soooo grateful if you ever did a one-off episode or extended segment where you just "chew the fat" about what it's like to code, drawing on that rare decades-long perspective (and super rapport) you guys offer. You already do this so well for security each week; even a single focused conversation about coding itself - habits, mindset, trade-offs, (omg, timescales!!!), how it feels over a lifetime... anything! - I'm sure would be incredibly valuable for people like me.

Thank you both for everything you already put into the show! It's a genuine highlight of my week seeing the SecurityNow logo pop up on my podcast feed. All the best, gorbash1370

I'd be glad to participate in something like that. It would be fun to grab a couple of other coders to join – Randal Schwartz and Father Robert come to mind. I think we'd have a ball. And assuming that the content was initially a Club TWiT exclusive, perhaps after some length of time it could be made available to non-club members so that our efforts could have general availability.

Troy (in Moncton, New Brunswick)

Hi Steve, Thanks for the years of great content! Been a listener since 2006 and really enjoy the weekly roundups you put together for us listeners.

The latest update to the Bitwarden's Browser extension (2025.11.1) broke the Passkeys integration that has been working perfectly for quite a while now. At first, like many in the community forum, I thought it was a Firefox update that messed up Bitwarden's functionality, but it ended up being a bug on Bitwarden's end: https://community.bitwarden.com/t/firefox-bw-extension-2025-11-1-not-prompting-for-passkeys-on-any-site/91252/14

The temporary solution brought forward by the moderators of the forum is to scale back to the previous version (2025.11.0), and turning off automatic updates for that extension. That solution has fixed the problem in my browser as well (Firefox on Linux).

Bitwarden is already working on the fix: https://github.com/bitwarden/clients/pull/17701

Maybe by next week's Security Now this will all be resolved, but just in case other listeners ran into this issue and didn't understand what happened, it might be worth a quick mention.

So, as Troy suggested, just a heads-up for anyone who may have stumbled over this. I'm sure Bitwarden will have this fixed immediately. I checked over on Github and found the comment about the fix, which read: *"Reverts some of the changes introduced by #17466 and takes a different approach to hiding the extension URL by injecting the script contents instead of linking to it."* So it sounds as though Bitwarden was working to further improve their browser extension and got tripped up somewhere along the way.

Grégory PAUL

Hello Steve, Regarding the deprecation of XSLT support, I'd like to draw your attention to the fact that this technology is very useful in the context of RSS feeds (which can be used for podcasts).

Indeed, while RSS feeds are mainly used by RSS readers or podcast apps, if a user opens an RSS feed directly in their browser, a use case is to have an XSLT stylesheet that provides a preview of the feed. A few years ago, browsers used to display XML feeds directly, but now they are downloaded instead, which makes them harder to view.

I created an open-source project that lets you send a link to an RSS feed, which I use as a bookmark or to send links to family members. There's a demo here: https://rsstodolist.eu/
I use an XSLT to display a proper rendering. I think I'll be able to use Google's suggested fallback (loading a library that emulates XSLT processing) or alternatively make two renderings: one in HTML for users, with an alternate link tag pointing to the RSS feed.

Thank you for your amazing work, Grégory from Paris, France, a long-time listener, spinrite owner and member of the TWiT Club ;-)

Since we talked about this week before last, and I then shared some of our listener's chagrin over Google's planned depreciation and then elimination of XSLT support, I was not aware of any intersection of XSLT with my life. But a couple of days ago, while working on GRC's website changes to support the release of the DNS Benchmark, I was puzzled by an error Windows' web server was producing.

Microsoft's IIS web server has become incredibly convoluted through the years as it's been mutated to retain backwards compatibility and a parade of features needed to remain competitive. Microsoft invented their own server-side scripting language known as "Active Server Pages". Then PHP refused to die. Then JAVA Server Pages became a thing. And of course Microsoft needed to add their beloved and ever-evolving DotNET-whatever into the server just to keep anything from ever stabilizing. And nothing that's ever come before has gone away. So we have support for server side includes, the original CGI interface and the newer FastCGI.

And each piece has been made into a module. So there's now an exceedingly long and ever lengthening pipeline of modules that are sequentially invoked to process each web request. So when nothing comes out the other end of the pipe the quandary is "where in the pipeline did the request die – exactly?" To answer this too-often-asked question, IIS has a feature called "Failed Request Tracing" which nicely does what its name suggests.

Through the years, I've needed to rely upon it from time to time to solve the sorts of mysteries that would otherwise be utterly impenetrable without a huge amount of trial and error.

Having covered the planned demise of our browser's XSLT-driven XML processing two weeks ago, I realized for the first time that IIS's Failed Request Tracing logs are output in XML format, and that it's only thanks to the presence of an innocuous 100K freb.xsl file, sitting quietly in the same directly, that double-clicking on the XML failed request trace file is able to produce a series of explorable web pages that are even remotely legible.

Gregory's note indicates that Google is suggesting a fallback, and it's clear that Microsoft will be needing to do something by this time next year, since it seems likely that our browsers are going to be losing the ability to ingest, process and display XSLT-reformatted XML files.

Bryan Kirchen

Hi Steve, Listener since episode 1. Thank you for twenty years of education and entertainment. It's crazy to think that I've spent a couple of hours with you in my ear each week for almost 40% of my life.

While I am a long-time listener, my family doesn't get as excited about keeping up on the security news of the week or learning exactly "how the internet works". As such, I haven't been very successful moving them from their current password chaos to Bitwarden.

I thought that AI might help me with my marketing better password practices to my family. I had ChatGPT write the lyrics and style prompt then Suno created the song. Inevitably, this attempt was also met with a shaking of heads and nearly-audible eye rolls.
https://youtu.be/G2XgCc3nj08

Undaunted, I'm hoping to get a full family conversion to Bitwarden this holiday season.
Thanks again for everything you do, I love the podcast. Here's to another 20 years!
Best, Bryan in Deerfield, IL

Leo, that's your cue: https://youtu.be/G2XgCc3nj08 Let's play as much of Bryan's creation as you feel is warranted. And thanks Bryan! Your family may be a lost cause, but at least they'll have you to clean up whatever mess and trouble they might get themselves into!

Robert Blaakmeer

Hi, The picture of the week (last week) is about what is known as (in the Netherlands) an "elephant path", and this particular one is located just outside the city of Tiel in the Netherlands. An instagram account published your picture 5 weeks ago. After it went viral the city of Tiel decided to fix it permanently... by removing the fence again. The photo below is the same spot just one week later: https://www.instagram.com/p/DQMWowpjNgT/. And here is a Google streetview from 2009, showing that the elephant path has been there forever :-)
https://maps.app.goo.gl/63HeNGZn6u8Hh16o6 Kind regards, Robert Blaakmeer

Robert provided us with two photos which I've grabbed for the show notes. We have a photo of the same path after the city decided to remove the ridiculous barricade. The two before and after photos looked so similar that I was initially a bit skeptical of whether the gate may have been removed by photoshop. But the two images show very different cloud cover in the sky above.

And Robert's second image, taken by Google Street View in 2001 (as seen by watermarks in the sky) answers the question we had last week about the shape of the path that we could not see. Now we know that the reason for the odd swerve (which elephants will presumably ignore along with cyclists and those on foot) is that another path goes off to the right in our original photos which is that pulls what would otherwise be a sane straight line path into the shape that we see, and which elephants are prone to ignore.

Finally, we also learn that we've given this altogether too much time, despite hosting yet another related cartoon about these "desire paths" as this week's picture.

Guy Watkins

Steve, Listening to VPN blocking laws... I decided George Orwell was an optimist!

I don't really believe that wholesale VPN banning could ever come to pass. I cannot imagine that an entire Internet technology which has many more applications than geo-relocation could be banned because one of the many things it can do is geo-relocate. And as we know, just bouncing traffic off a proxy server located elsewhere will have the same effect while not being a VPN.

Though I don't know what **will** stop it from happening, it feels that something needs to.

Ethan Stone

Hi Steve, I listened to the latest Security Now and thought I'd fill you in on what happens to people using VPNs right now.

First, it's important to know that a lot of sites are currently screening for IP addresses that are

associated with a VPN. I don't know how they're doing it, although I suspect there are commercial services that try to keep track of the latest IP addresses of popular VPNs and create continuously updated blacklists. But empirically, it's obvious that it's happening right now.

Second, I think I have a different perspective on this because I am almost always surfing the web on a VPN using a browser that has few or no cookies and isn't logged into Google or anything else that would identify me. As I've mentioned before, I'm one of your more paranoid listeners. As a result, my experience on the web differs significantly from what most people encounter.

Given all of that, once a site has identified me as using a VPN, various bad things can happen. I never use a VPN when I'm trying to login to my account at a financial services company because they commonly refuse to let me login at all. But lots of other sites seem to be monitoring for VPN IP addresses and trying to exclude or treat differently any visitor coming from one.

For example, I often have to cycle through several VPN servers when I want to see a YouTube video before I find an IP address Google hasn't blacklisted yet. That probably doesn't happen to you because you watch YouTube while logged into a Google account. But, as noted, that's not me. So I guess I stand out and look suspicious to Google. If I use a VPN Google can identify, the videos often either fails outright or YouTube requests me to login so they can check my age or verify my identity. But that's just one example. It happens to me all the time to the point that if anything on a website doesn't seem to be working right, my first instinct is to cycle to another server. And at some point, before I contact customer service, I'll try dropping the VPN outright to see if that helps.

It's worth noting that, for some weird reason, sites never tell you outright, "We've identified you as using a VPN, please drop it." They just make things fail in unexplained ways. I'm not sure why, but it's universal. I don't think I've ever gotten a message just telling me to drop my VPN.

So I thought it might be interesting for you to get a report from the tiny corner case where I spent my time online. I love the show. Thanks for everything you do. Ethan Stone

That's interesting and valuable feedback, Ethan. Thank you. I hadn't thought about it before, but sometimes when I'm doing a bit of research on a failed GRC web forums account creation, I'll see what's known about the IP they were using. The XenForo forum software links to "WhatIsMyIPAddress.com" and I'll often see that it's identified as a VPN. So Ethan may be correct in assuming that there is an available database of VPN exit-point IPs and that websites are treating such visitors differently due to far higher incidents of fraudulent activity originating from VPN users.

Jacob

Hi Steve, I am coming to you in search of a solution to a problem I have little experience with. My grandmother frequently uses Apple IIgs programs for her piano studio. She does not have copies of the disk, and they have an unknown copy protection on them. They are 3.5" floppies and we only have one working drive for them. I'm going to try to use ADTpro to get a .NIB copy of the disks, but from what I've found, that is unreliable with the 3.5" disks. I know you have a lot of experience with spinning media and I was wondering if you had any suggestions

for making copies (or digitizing) these disks. Sincerely, Jacob.
p.s. I love the show, keep up the good work.

This is a bit of an odd-ball question, but I thought our listeners might enjoy my reply to Jacob. I replied to him:

Hi Jacob. The problem is that the formatting of 3.5" diskettes is largely software defined. As such, they can have any sort of bizarre physical formatting that would be impossible to duplicate without some sort of very specialized equipment. Assuming that the diskette's copy protection details are unknown and undocumented, it would be impossible to even know where the protection was stored.

For example, diskette media is self-clocking where only the speed of the spindle and the frequency of the data being written determines the placing and spacing of the bits on the magnetic medium. If a drive motor was spinning just a bit faster than normal while a track's data was being written, the end of one track might start to overwrite the start of that track because the too-fast spinning would bring the track's start back around too soon. This problem is not just theoretical. To prevent this from happening, diskette tracks contain a "dead zone" at their end. This allows some "slack" in case of a too-fast spindle motor. Consequently, when looking for some place to place a bit of copy protection authentication information that would never be copied by duplication software, some copy protection systems write an additional small bit of data in that slack region. Normal software doesn't know to look there, but the copy protection code does.

Another example is the use of another additional cylinder. Diskettes determine where their head is by incrementally steeping inward or outward. But anytime they cannot find the sector they're looking for, they seek to cylinder 0 to "recalibrate" and then step out again. Most diskette drives contain an optical sensor to let the diskette controller know when the head has reached cylinder 0. But Apple saved a buck by eliminating that sensor. Apple's drive just runs the drive's head back into a hard mechanical stop. This is why Apple's drives made some disquieting noises when they were recalibrating their head positions. Once the drive seeks to cylinder 0, it then counts cylinders as it moves inward. But who says that a drive can only record 80 tracks? Sure, 80 is the official track count. But why not 81? If the 80th track is reliably read and written, chances are that the 81st track would be too. So the unofficial track 81 could also well be where a copy protection system might choose to store its data.

And one last trick might simply be some deliberately mis-written sectors. Normal diskette software places checksums on sector headers and sector data. Normal software won't read sectors with bad headers and data. This might be what the ADTpro diskette copying software will read, if it can. But writing deliberately damaged sectors again another trick that diskette copy protection systems have used.

Jason Egan

Hey Steve! I recently came across this game and thought you might be interested. I like to imagine this is a way of conceptualizing efficiently flipping bits, but I could be way off. Either way, my kids and I have enjoyed the challenges it presents - some can be really tricky! The best part is watching my kids develop their brain's muscle memory as they start to discover patterns during the unflip process of each board, much like the Tower of Hanoi game. Let me know your thoughts, and thanks for keeping us all informed and entertained!

Thanks, Jason. Several of our listeners who know of my penchant for puzzles without a timer also saw this and thought of me. So a thanks to everyone else as well. https://unflipgame.com/

The URL is just "unflipgame.com". It's a toy that runs entirely within the browser thanks to a bit of JavaScript and I have already spent some enjoyable time with it. The puzzle begins with an N by N grid of squares – N being a small number like 5 or 6. And that square grid contains an initial starting pattern with some squares being black. The goal is to turn the entire grid white. This is done by dragging the mouse from one corner of your own square to the opposite corner. Once you release the mouse all of the squares contained with that newly drawn square invert their black or white coloration. So it's an XORing puzzle. You quickly learn that you're only able to invert square regions. So that's an important limitation. The initial levels of the puzzle are nicely designed to teach the basics and to show some of the more important concepts.

The puzzle has a moves counter and "best" and a "par" indication to show what's possible. It is possible to just keep pounding on the poor thing, trying this and that and going around in circles, racking up moves. But the fun is in using some planning and finesse to always complete the "whitening" in the fewest moves.

I like it a lot. It's "unflipgame.com" and I recommend it.

Bob Sudduth (**Sud**duth)

Long time listener (before episode 50), Spinrite owner, and "old" (about you and Leo's age, but we're not old).

My question has to do with passkeys and maybe digital ids (I have done yet). I am a treasurer for a local church. Many of the government sites want me to use login.gov or id.me, which is fine. But I have two "roles": one as me and my personal accounts, and one as a treasurer. I haven't figured out how to use a passkey and have two roles. I have purposely used my church's treasurer email for all church business so I can one day hand all of those accounts over to someone else (I use Bitwarden). I even have two user accounts on my computer to separate what I do. My bank is greatly confused and continually tries to link my personal account with the church's account. I end up at the Social Security site for my information instead of being able to file tax information for the church. I get it that I'm one person, but that doesn't mean I own all the funds in my church's accounts.

Are passkeys so simple, that I'm making this hard? Am I missing something? Will Digital IDs cause the same issue?

Bob, I'm wondering whether the confusion at your bank might be due to remaining logged in with one identity when attempting to login with another? Might that be causing the linkage problem.

Multiple passkeys per single replying party (the website in this case) is a common need and as far as I know all of the passkeys implementations allow for multiple passkeys to be associated with a single website. When you have two assigned – for example, one for you and another for your church's treasurer who happens to also be you at the moment – your passkey authenticator should prompt you with which one you wish to use.

Note that this is different from wishing to be able to use multiple different passkeys to login to the same account. In the need you explained, you're definitely wishing to be logging into different accounts using different passkeys at the same site.

Doing that should be possible, simple, straightforward and clear.

Chad

Hi Steve - AI isn't all it's hyped up to be - I asked ChatGPT to help me identify the 12 disks in the JBOD I'd recently attached to this host. The host already has a 16 disk JBOD attached. It identified the two enclosures BUT it literally reversed them.

It told me to run a command to create a new zpool only it gave me disks from the 16 bay unit not the 12. Since the 12 had disks from a previous pool I knew I needed a force parameter with zpool, thereby putting the data on my 16 disk enclosure at serious risk. Thankfully a wc -l command caught chat's screw up and my data is still safe.

I had provided the command and output it asked for, yet a simple basic task it could not do without making a serious mistake. I'm not worried AI will replace us humans anytime soon. -Chad

One of the things I hear Leo and Leo's AI-informed hosts and guests noting frequently is that today's AI is only as good as the depth and breadth of its training data. The key thing to appreciate is that today's AI doesn't actually ***UNDERSTAND*** anything that it is saying. What's so frigging astonishing about what we have today is that just by being what Leo originally described as a fancy spelling corrector, today's AI is able to do as much as it can and to ***appear*** to actually know what it's talking about. It does this so astonishingly well that it's easy to be seduced by it.

I have a perfect example from my own recent experience. Last week I needed to multiply a 64-bit integer by a 32-bit integer. Naturally, my language is Intel assembly code and I could not assume that the user of the DNS Benchmark would have a 64-bit processor. So I needed to only use 32-bit instructions. Anyone who has played with machine language knows that a 64-bit by 32-bit multiplication can be performed using a pair of 32-bit multiplies while saving the high-half of the first result and later adding that to the low-half result of the second multiplication. This is exactly what we do on paper when we multiply a two digit number of a one digit number.

I was curious to see what Chat-GPT's best code smithing model would suggest. It was an almost comical disaster. It was very sure of its result which was utter nonsense. It even added some helpful comments to the code which just added insult to injury.

Why can't AI do something so basic? Because there is not a ton of preexisting Intel assembly language code on the Internet for the model to have previously trained on. Sure, that's some. So it spewed out some nonsense. But that was all. Ask it something about Python or PHP or C and stand back because you often get near-perfect amazingly complex code. But that same AI cannot produce the code to multiply a 32-bit integer by a 64-bit integer using 32-bit Intel instructions. Not even close.

So my point here, Chad, is that you asked the AI something for which there is not a huge body of very specific knowledge and examples. Your question assumed that it actually understood what was going on in your system. But it's just a pattern finder and pattern matcher. It's an astonishingly good pattern finder and matcher. But for now at least, that's all it will ever be.

And this is, of course, the crux of the big multi-trillion dollar question: Can LLMs ***ever*** be more than this? Is this the way forward? Or is this a tantalizing dead end on the way to more? There are many AI researchers who, today, still consider all of this to be a very very expensive parlor trick. Useful? Yes. Absolutely. And, unfortunately, people whose employment is reducible to

sophisticated pattern finding and matching are in trouble today and tomorrow. Those jobs are gone. But this may be all there is. This may not be the road down which another breakthrough awaits.

Jacob

Hi Steve, I just wanted to send a long-overdue thank you.

I've been in this industry for about 30 years now, and I was a Unix guy before this whole Linux thing showed up and started acting like it invented multiuser systems. In all that time, very few individuals have consistently inspired me the way you have. That's not something I say lightly – especially not as a crusty old Unix admin who usually meets "gurus" with a raised eyebrow and a large dose of skepticism.

These days I listen to Security Now while walking my dog. He's a big boy, so the walks are long – which is perfect, because your deep dives are too. Somewhere between SYN packets, SQRL, and side-channel attacks, it really hit me how much I've learned from you over the years, and how much your way of thinking has influenced mine. You've been a mentor at a distance for a long time, whether you knew it or not.

I'm definitely not a young pup anymore, but your mix of curiosity, rigor, and stubborn refusal to accept hand-wavy explanations keeps my own curiosity sharp. You don't just report on security; you teach it, and you do it in a way that respects the listener's intelligence. That's rare.

So this is just a heartfelt thank you from a long-time Unix greybeard who's spent decades in the trenches and still looks forward to every episode. Best regards, Jacob

I decided to share this posting of Jacob's note because it meant a lot to me and because I usually skip sharing this sort of feedback unless it's just a "thanks for all you guys do" tacked onto the end of something else. What meant so much to me was that Jacob understood what I'm sure most of our listeners understand, which is that I am always trying to find the larger underlying principles behind the news. I'm working to knit everything that's going on, that we talk about every week, into an historical and contextual framework that places it in proper perspective and imbues it with some meaning. My hope is that someday, when I'm no longer able to spend this time with everyone every week, those who have had the chance to join us for at least several years of this journey will retain that framework, which will continue to be useful as future events unfold.

Sci-Fi

A new StarGate coming from Amazon and MGM.
We must have talked about the Stargate science fiction series through the 20+ years of this podcast. I have been a huge fan of the Stargate franchise through its many years. It was often the case that it was the only source of good science fiction programming. Part of that was a love for the various original cast members who I really enjoyed, and part was an appreciation for the writing which was also often great. The strongest well known personality on the Stargate SG-1 series was Richard Dean Anderson who many know from the roles that made him famous as McGyver. He maintains that same snarky sassy humor in Stargate, which works quite well.

For those who may not know, and this is no big spoiler, the concept is that an ancient race of technologically advanced, brutal and not very nice aliens created a massive network of circular portals which we humans dubbed "Stargates." We called them stargates because any pair of them can be interconnected by dialing the far gate's "gate code" – sort of like an intergalactic IP address.

Wikipedia, which has an extensive page about Stargate explains that the pair of stargates are linked by what is informally known as a "wormhole" but is technically an Einstein–Rosen bridge.

What I always appreciated about this concept as a vehicle for science fiction storytelling was that it very cleverly gave the writers an infinitely large blank canvas. In Star ***Trek***, Kirk, Spock, McCoy, Scotty and the rest of the crew roamed around in the Enterprise and stories were wound around whatever they might find on whatever planet they beamed down to.

Similarly, in Stargate, after first discovering a lone, abandoned and long buried Stargate on the Giza plateau in Egypt, after figuring out how to turn it on and discovering that there might be some very mean aliens on the other end of the wormhole, a new military branch is formed to systematically explore the gate network. So teams of explorers would systematically dial gate codes consisting of a string of alien symbols. Upon the entry of the final 7th symbol, a silvery liquid-appearing "event horizon" would form across the gate's aperture, and our intrepid explorers would plunge in not knowing what to expect. The beauty of this was that it gave Stargate's writers total freedom, much like whatever next planet and people Star Trek's writers might cook up.

We're talking about Stargate today because last Wednesday Amazon Prime and MGM Studios announced their intention to bring a new Stargate series back to streaming. Their announcement has had nearly one million views in the past week and past fans of the show are excited because two of the franchise's original creators will be driving the rebirth forward.

In my opinion, Stargate is an often overlooked and quite solid science fiction franchise. It ran longer than any of the many various Star Treks and, like Star Trek, spun off several variations and five feature length movies. Any of our listeners who have access to Amazon Prime, where the franchise lives, and some children of an appropriate age might find a great deal of child-appropriate content in the many years of its programming. Stargate SG-1 went for 10 seasons of 22 and then later, 20 episodes each. Stargate Atlantis was 5 seasons of 20 episodes. Stargate Universe had two, 20-episode seasons. There's a lot there and much of it is very good.

No one knows when Amazon's new Stargate will show up, but I'm looking forward to it.

Bots in the Belfry

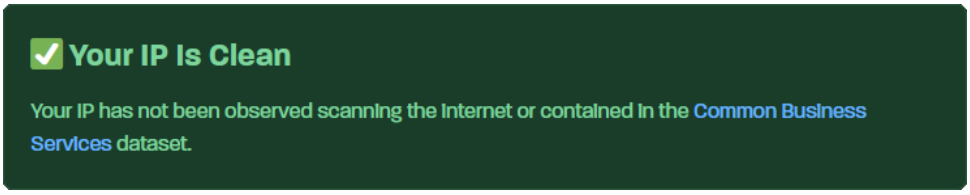
Last Thursday, BleepingComputer brought us the news that the reputable and well known security firm GreyNoise Labs was offering a new service to check – and even to optionally continuously check – user IP addresses for their association with known Bot activity. Here's what BleepingComputer wrote:

> *GreyNoise Labs has launched a free tool called GreyNoise IP Check that lets users check if their IP address has been observed in malicious scanning operations, like botnet and residential proxy networks.*
>
> *The threat monitoring firm that tracks internet-wide activity via a global sensor network says this problem has grown significantly over the past year, with many users unknowingly helping malicious online activity. GreyNoise said: "Over the past year, residential proxy networks have exploded and have been turning home internet connections into exit points for other people's traffic."*

I'll just note that this does track with some of the more recent reporting we've seen and shared here, regarding the number of IP addresses that have been involved in recent high bandwidth and also scanning and probing attacks. When we hear that hundreds of thousands of bots are enlisted in attacks, those must all be somewhere – and some one's. BleepingComputer continues:

> *Sometimes folks knowingly install software that does this in exchange for a few dollars. More often, malware sneaks onto devices, usually via nefarious apps or browser extensions, and quietly turns them into nodes in someone else's infrastructure. While there are ways to determine if someone has become part of malicious botnet activity, like examining device logs, configurations, network traffic, and activity patterns, a tool that simply checks the IP address is the least intrusive method. Anyone visiting the scanner's webpage will get one of the three possible results:*
>
> - *Clean: No malicious scanning activity detected.*
> - *Malicious/Suspicious: The IP has shown scanning behavior. Users should investigate devices on their network.*
> - *Common Business Service: The IP belongs to a VPN, corporate network, or cloud provider, and the scanning activity is normal for those environments.*

I'll note that BleepingComputer casually used the term "scanner" which this is not. A scanner scans, whereas what GreyNoise does is passively collect and collate Internet traffic from across their widely dispersed global sensor network. So, when I use their "GreyNoise IP Check" facility, I receive an instantaneous response that displays my network's public IP and a notification which in this case says:



Since this is safe, quick, simple and interesting, I've given GreyNoise's service the GRC shortcut of "botcheck". So you can simply enter grc.sc/botcheck into your browser's URL and you'll be bounced over to GreyNoise's page at: https://check.labs.greynoise.io/ which will perform an instantaneous lookup of the public IP your browser's request is coming to GreyNoise from, against their dynamically updated database of known problematic IP addresses.

IPv6 gurus grumble incessantly about the ubiquitous presence of NAT routers which they are quite certain have ruined the Internet. They doggedly – to this day – cling to the original concept of a vast network defined by "one IP for one host." In this original conception of the Internet, there is no IP sharing because there are plenty of IPs to go around. Well, we all know that's not what happened. Even though IPv6 really was defined early enough to replace IPv4 and prevent what these gurus see as the scourge of NAT, we have all seen just how unwilling the world is at every level to change away from something that's working. The contrary view is "Why change? NAT works great! Everyone's using it."

I mention this in the context of GreyNoise's very cool free "botcheck" facility because in this instance, NAT really is serving as a huge boon. Everyone's use of gateway NAT routers means that all of the random PCs and phones and tablets and NASs and wacky IoT gadgets we may have encrusting our networks will all have and be sharing a single common public IP presence. This means that asking GreyNoise what **they** think of your single public IP address automatically incorporates the collective behavior of every device you have perched on your LAN behind your NAT router. In other words, receiving a clean bill of health automatically means that you can be reasonably certain that not a single one of the myriad devices on your network has been misbehaving.

Of course, the flip side of this is that if GreyNoise comes back with the appraisal that your network's IP has been seen misbehaving and participating in some attacks – as a growing number of networks and devices have been – then the onus will be on you to determine what device (or possibly devices) behind your NAT has been compromised. But at least you'll know that you have a problem.

Given this, it's a no-brainer to recommend that everyone listening should go to grc.sc/botcheck to quickly confirm that none of the devices that are sharing their network's IP have been seen to misbehave. BleepingComputer provided a bit more information, writing:

> *When any malicious activity is correlated with the provided IP address, the platform will also include a 90-day historical timeline, which may help pinpoint a potential infection point. For example, when the installation of a bandwidth-sharing client or a shady application precedes malicious scanning, strong correlations can be made that enable remediation action.*
>
> *For more technical users, GreyNoise also provides an unauthenticated, rate-limit-free JSON API, accessible via curl, which can be integrated into scripts or checking systems. If your scan results show 'Malicious/Suspicious,' it's a good idea to start the investigation by running malware scans on all devices on the same network, especially focusing on devices like routers and smart TVs.*

BleepingComputer concludes with the generic advice: "Users are advised to update their devices to the latest available firmware, change admin credentials, and disable remote access features if they're not needed."

So, grc.sc/botcheck. I expect this free and quick service to become quite popular. It's a win.